

Security+ 5.2 · Risk Management Strategies

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 5.2 — Risk Management Strategies (3:12)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Resposta ao risco: MITIGATE (reduz com control); TRANSFER (passa pra outro — seguro, terceiro); ACCEPT (aceita e assume residual, documentado); AVOID (não faz a atividade).

Highlights que a prova cobra

- MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual.
- AVOID: não faz a atividade — a resposta mais radical

Dicas de prova & Cenários Típicos

- 'purchasing cyber insurance'=risk transfer

Cenário clássico de exame: 'empresa compra seguro de cyber'=transfer (o risco segue, a seguradora paga).

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 5.2 — Risk Management Strategies)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?

- A)** Aceitar o risco
- B)** Evitar o risco
- C)** Transferir o risco
- D)** Mitigar o risco

2. Cenário corporativo (Risk Management Strategies): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Risk Management Strategies): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'AVOID: não faz a atividade — a resposta mais radical'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: AVOID: não faz a atividade — a resposta mais radical...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Risk Management Strategies): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'purchasing cyber insurance'=risk transfer'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'purchasing cyber insurance'=risk transfer...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Risk Management Strategies): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'empresa compra seguro de cyber'=transfer (o risco segue, a seguradora paga)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'empresa compra seguro de cyber'=transfer (o risco segue, a seguradora paga...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Risk Management Strategies): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual....

7. Cenário corporativo (Risk Management Strategies): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'AVOID: não faz a atividade — a resposta mais radical'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: AVOID: não faz a atividade — a resposta mais radical...

8. Cenário corporativo (Risk Management Strategies): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'purchasing cyber insurance'=risk transfer'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'purchasing cyber insurance'=risk transfer...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Risk Management Strategies): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'empresa compra seguro de cyber'=transfer (o risco segue, a seguradora paga)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'empresa compra seguro de cyber'=transfer (o risco segue, a seguradora paga...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Risk Management Strategies): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual....
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRADORES

1) C — Transferir o risco.

✓ **Por que está certa:** A alternativa correta é: Transferir o risco. No domínio de Gestão de Riscos da CompTIA Security+ SY0-701, as respostas ao risco incluem evitar, mitigar, transferir e aceitar. A transferência de risco ocorre quando a organização repassa a responsabilidade financeira por um risco a terceiros, tipicamente por meio de seguros cibernéticos, contratos de outsourcing ou cláusulas de indenização. Ao contratar um seguro cibernético, a empresa paga um prêmio para que a seguradora cubra prejuízos decorrentes de ataques, como custos de recuperação, multas regulatórias, extorsão e responsabilidade civil. É importante notar que a transferência não elimina o risco em si (o ataque ainda pode ocorrer), mas transfere o impacto financeiro. A organização ainda deve manter controles de segurança para gerenciar a probabilidade e o impacto residual.

✗ **Por que as outras estão erradas:**

- *Aceitar o risco:* Aceitar o risco significa reconhecer a existência de um risco e decidir não tomar nenhuma ação para mitigá-lo ou transferi-lo, geralmente porque o custo da mitigação excede o benefício ou porque o risco é considerado aceitável dentro do apetite da organização. Contratar um seguro não é aceitar o risco, pois envolve uma ação ativa de transferência financeira. A aceitação é passiva e não envolve terceiros.
- *Evitar o risco:* Evitar o risco significa eliminar a atividade ou o processo que gera o risco. Por exemplo, desativar um serviço vulnerável ou proibir o uso de dispositivos USB. Contratar um seguro não evita o risco; a atividade continua existindo e o ataque ainda pode ocorrer. A evitação é uma mudança de comportamento para eliminar a exposição, enquanto o seguro lida com as consequências financeiras.
- *Mitigar o risco:* Mitigar o risco significa implementar controles para reduzir a probabilidade ou o impacto de um incidente. Exemplos incluem firewalls, criptografia, treinamento de conscientização e backups. Contratar um seguro não reduz a probabilidade de um ataque nem o impacto técnico; ele apenas compensa financeiramente as perdas. Portanto, não é uma medida de mitigação, mas de transferência.

2) B — Implementar a solução correspondente: MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management Strategies): MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) B — Implementar a solução correspondente: AVOID: não faz a atividade — a resposta mais radical....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701)

para a aula 5.2 (Risk Management Strategies): AVOID: não faz a atividade — a resposta mais radical.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) A — Implementar a solução correspondente: 'purchasing cyber insurance'=risk transfer....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management Strategies): 'purchasing cyber insurance'=risk transfer.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: 'empresa compra seguro de cyber'=transfer (o risco segue, a seguradora paga....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management Strategies): 'empresa compra seguro de cyber'=transfer (o risco segue, a seguradora paga)..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual.....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management Strategies): MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: AVOID: não faz a atividade — a resposta mais radical....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management Strategies): AVOID: não faz a atividade — a resposta mais radical.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: 'purchasing cyber insurance'=risk transfer....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management Strategies): 'purchasing cyber insurance'=risk transfer.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: 'empresa compra seguro de cyber'=transfer (o risco segue, a seguradora paga....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management Strategies): 'empresa compra seguro de cyber'=transfer (o risco segue, a seguradora paga)..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual.....

✅ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management Strategies): MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual..

❌ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.